

경계 중심 Threat Modeling as Code 기반 AI 추론
시스템 (LLM 기반 서비스 포함)을 위한
정책 · 위협 시그널 · 테스트 동기화 시스템 및
방법

목차

1. Title of Invention (발명의 명칭).....	3
2. Technical Field (기술분야).....	3
3. 발명의 상세한 설명 (Detailed Description)	3
3.0 Symbols, Abbreviations, Terms (기호, 약어 및 용어 정의)	3
3.0.1 Threat / Vulnerability / Risk (Threat Modeling 의 일반 정의).....	3
3.0.2 모델링의 기준 단위 (Trust Domain / AI Boundary)	4
3.0.3 AI / 경계 기반 위협 개념 (Threat Modeling 의 AI Boundary 적용)	4
3.1 Technical Problem to be solved by the invention (해결하고자 하는 기술적 과제)	6
3.1.1 기존 AI 추론 시스템 보안의 한계	6
3.2 Detailed Description of the Invention (발명의 구체적 내용)	7
3.2.1 기존 구조 및 동작 방법.....	7
3.2.2 제안 시스템 구조.....	8
3.2.3 Closed Loop 기반 AI Boundary 처리 워크플로우	11
4. Claims of the Invention (청구범위).....	16
[Claim 1] – 메인 독립항 (System Claim)	16
[Claim 2] – Risk 계산 로직을 포함하는 시스템	17
[Claim 3] – Risk 기반 기준 갱신을 포함하는 Closed Loop 시스템.....	18
[Claim 4] – Threat Signal Engine 의 구현 구성을 포함하는 시스템.....	18
[Claim 5] – AI Boundary 기반 Risk-Driven 보안 처리 방법 (방법 청구항)	18
5. Effects of the Invention (발명의 효과)	19

1. Title of Invention (발명의 명칭)

경계 중심 Threat Modeling as Code 기반 AI 추론 시스템(LLM 기반 서비스 포함)을 위한 정책·위협 시그널·테스트 동기화 시스템 및 방법

BOUNDARY-CENTRIC THREAT MODELING AS CODE BASED SYSTEM AND METHOD
FOR SYNCHRONIZING POLICY, THREAT SIGNALING, AND TESTS
FOR AI INFERENCE SYSTEMS INCLUDING LLM-BASED SERVICES

2. Technical Field (기술분야)

본 발명은 AI 추론 시스템의 보안 기술 분야에 관한 것으로서,
특히 대형 언어 모델(LLM: Large Language Model)을 이용하는 애플리케이션 또는 서비스 (예: 3rd party LLM API, 온디바이스(on-device) LLM 프레임워크 포함)를 중심으로 설명되지만, 유사한 구조를 갖는 기타 AI 추론 엔진에도 동일하게 적용 가능한 Boundary-Centric Threat Modeling as Code(TMaC) 기반 정책(Policy)·위협 시그널(Threat Signal)·테스트(Test)의 동기화 시스템 및 방법에 관한 것이다.

3. 발명의 상세한 설명 (Detailed Description)

3.0 Symbols, Abbreviations, Terms (기호, 약어 및 용어 정의)

3.0.1 Threat / Vulnerability / Risk (Threat Modeling 의 일반 정의)

구분	내용
Threat (위협)	시스템, 데이터 또는 자산에 대해 보안, 프라이버시, 안정성 또는 컴플라이언스 상의 피해를 유발할 수 있는 잠재적인 공격 원인, 공격 행위 또는 공격 시나리오를 의미한다. Threat 는 특정 기술이나 구현에 한정되지 않으며, 공격자의 의도, 능력 또는 환경적 요인에 의해 발생할 수 있다.
Vulnerability (취약점)	Threat 가 실제로 발생하거나 성공할 가능성을 증가시키는 시스템의 구조적, 설계적 또는 구성상의 약점을 의미한다. Vulnerability 는 시스템의 설계, 구현, 구성 또는 운영 방식에 따라 형성될 수 있으며, 단독 또는 다른 취약점과 결합되어 Threat 의 성공 가능성을 높일 수 있다.

Risk (위험)	Threat 가 Vulnerability 를 악용하여 실제 피해가 발생할 가능성과, 그로 인해 발생하는 영향의 크기를 결합하여 평가되는 위험 수준을 의미한다. Risk 는 Threat 의 발생 가능성(likelihood)과 발생 시 영향(impact)을 종합적으로 고려하여 산출될 수 있다.
-----------	---

3.0.2 모델링의 기준 단위 (Trust Domain / AI Boundary)

구분	정의
Trust Domain (신뢰 도메인)	Trust Domain 은 서로 동일한 보안 정책, 신뢰 수준 및 권한 관리 체계를 공유하는 논리적 또는 물리적 영역을 의미한다. 예를 들어, 사용자 영역, 백엔드 서비스 영역, AI 추론 영역, 외부 AI 제공자 영역 등은 각각 서로 다른 Trust Domain 으로 구성될 수 있다. <pre> graph TD subgraph Local_Inference_Trust_Domain [Local Inference Trust Domain] direction TB TD1_L["사용자 영역 (Trust Domain #1) 사용자 입력이 생성 및 전달되는 영역"] TD2_L["백엔드 서비스 영역 (Trust Domain #2) -Prompt Builder -Threat Signal(Threat Evaluator) -Policy Gateway"] TD3_L["AI 추론 영역 (Trust Domain #3) -AI Inference Engine -On-device LLM"] TD1_L <--> TD2_L TD2_L <--> TD3_L end subgraph External_Provider_Trust_Domain [External Provider Trust Domain] direction TB TD1_E["사용자 영역 (Trust Domain #1) 사용자 입력이 생성 및 전달되는 영역"] TD2_E["백엔드 서비스 영역 (Trust Domain #2) -Prompt Builder -Threat Signal(Threat Evaluator) -Policy Gateway"] TD3_E["External AI Provider 영역 (Trust Domain #3) -AI Inference Engine -LLM Runtime"] TD1_E <--> TD2_E TD2_E <--> TD3_E end </pre>
AI Boundary (AI 경계)	AI Boundary 는 서로 다른 Trust Domain 에 속하는 컴포넌트들 사이에서 데이터 또는 제어 정보가 교환되는 논리적 경계를 의미한다. AI Boundary 는 AI Boundary Threat, AI Boundary Vulnerability 및 AI Boundary Risk 를 정의·분석·관리하기 위한 기본 기준 단위로 사용된다.

3.0.3 AI / 경계 기반 위협 개념 (Threat Modeling 의 AI Boundary 적용)

구분	내용
----	----

AI Boundary Threat (AI 경계 위협)	AI Boundary Threat 는 AI 시스템에서, 서로 다른 Trust Domain 간에 형성된 AI Boundary 에서 AI 추론 엔진 또는 대형 언어 모델(LLM)을 악용하거나,해당 Boundary 를 통과하는 데이터 또는 제어 흐름을 오·남용함으로써 보안, 프라이버시 또는 컴플라이언스 상의 피해를 유발할 수 있는 Threat 를 의미한다. 즉, AI Boundary Threat 는 일반적인 Threat 개념을 AI Boundary 단위로 구체화한 것이다.
AI Boundary Vulnerability (AI 경계 취약성)	AI Boundary Vulnerability 는 AI 시스템에서, 특정 AI Boundary 와 특정 AI Boundary Threat 의 조합에 대하여 상기 Threat 가 성공적으로 발생하기 쉽게 만드는 시스템의 구조적 또는 구성적 Vulnerability 를 의미한다. 이는 일반적인 Vulnerability 개념을 AI Boundary 단위로 구체화한 것이다. 예를 들어, • Prompt Boundary 에서 시스템 프롬프트와 사용자 입력을 분리하지 않는 설계, • Tool Boundary 에서 고위험 도구 호출에 대한 추가 통제 없이 허용하는 구성, • Provider Boundary 에서 Threat Modeling as Code 정의와 불일치한 설정 등이 AI Boundary Vulnerability 에 해당할 수 있다.
AI Boundary Risk (AI 경계 위험)	AI Boundary Risk 는 AI 시스템에서,특정 AI Boundary–AI Boundary Threat 조합에 대하여 Threat 발생 가능성과 발생 시 영향을 결합하여 평가되는 위험 수준을 의미한다. AI Boundary Risk 는 일반적인 Risk 개념을 AI Boundary 단위로 적용한 것이며, 본 발명에서는 다음 정보를 기반으로 동적으로 산출·갱신된다. • Threat Modeling as Code(TMaC)에 정의된 Threat 및 Control 정보 • Threat Evaluation Store 에 축적된 위협 이벤트(Threat Signal) • 정책 적용 결과 및 테스트 결과
Closed Loop 구조 (AI Boundary Threat Handling Loop)	본 발명에서의 Closed Loop 구조란, AI Boundary 단위로 정의된 Threat, Vulnerability 및 Risk 가 개별적으로 관리되는 것에 그치지 않고, Threat 처리 결과 및 평가 정보가 다시 Threat 및 Risk 산출 기준에 반영되어, 동일한 AI Boundary Threat 에 대한 대응 기준이 지속적으로 보정·강화되는 순환 구조를 의미한다. 상기 Closed Loop 구조에 따라, AI Boundary Threat 는 단발성 이벤트가 아닌 누적·관리 가능한 대상으로 취급되며, AI Boundary Risk 는 Threat 의 실제 발생 양상 및 정책 적용 결과를 반영하여 동적으로 산출·갱신된다.

3.1 Technical Problem to be solved by the invention (해결하고자 하는 기술적 과제)

본 발명은 AI 추론 시스템의 보안 설계 및 운영 과정에서 발생하는 구조적 한계를 해결하기 위한 것으로서, 특히 AI Boundary 단위에서 발생하는 위협을 정책, 탐지, 테스트 및 위협 평가와 동기화하여 관리하지 못하는 문제를 해결하는 것을 기술적 과제로 한다.

3.1.1 기존 AI 추론 시스템 보안의 한계

(1) 모델 내부 중심 위협 모델링의 한계

기존 AI 추론 시스템 보안에 관한 논의는 주로 모델 내부 안전성 또는 프롬프트 설계와 같은 요소에 집중되어 왔다.

그러나 실제 보안 위협은 클라이언트, 백엔드 서비스, AI 추론 엔진 제공자, RAG 인덱스 및 외부 도구 간의 상호작용 과정에서 발생하는 경우가 많으며, 이들 사이에 형성되는 AI Boundary 단위의 Threat 를 정규화하여 관리하는 체계적인 프레임워크는 부족하다.

(2) Threat Modeling 과 정책·탐지·테스트의 분리

Threat 모델링은 일반적으로 문서(PPT, Wiki 등) 형태로 수행되는 반면, Policy Gateway 설정, 위협 탐지기 구성 및 E2E 테스트는 각기 독립적으로 관리되는 경우가 많다.

이로 인해 설계 단계에서 정의된 Threat 및 Control 과 실제 운영 환경에서 적용되는 정책, 탐지 및 테스트 간의 동기화(synchronization)가 어렵고, 그 결과 보안 통제의 불일치(drift)가 빈번하게 발생한다.

(3) Threat 이벤트 관찰과 Vulnerability / Risk 관리의 단절

기존 보안 시스템은 개별 요청 단위의 로그 또는 탐지 이벤트를 기록하는 데에는 효과적이지만, 특정 AI Boundary-Threat 조합에 대하여 현재 취약성 수준(Vulnerability)이나 위험 수준(Risk)을 정량적으로 추적·관리할 수 있는 경계 단위 Vulnerability/Risk 관리 레이어는 부족하다.

(4) AI 추론 시스템 특화 취약점(LLM 기반 서비스 포함)의 Boundary / TMaC 관점 매핑 부재

Prompt Injection, RAG Indirect Injection, Insecure Output Handling 등과 같은 AI 추론 시스템 특화 취약점은 다양한 연구 및 가이드라인을 통해 제시되고 있으나, 이러한 취약점을

AI Boundary 및 Threat Modeling as Code(TMaC) 스키마와 연결하여 정책 적용, 위협 탐지, 테스트 수행 및 위협 평가를 end-to-end 로 동기화하는 체계적인 프레임워크는 거의 존재하지 않는다.

3.2 Detailed Description of the Invention (발명의 구체적 내용)

본 발명은, 동일한 두 계층 구조를 갖는 Boundary-Centric Threat Modeling as Code(TMnC) 기반 시스템을 제공한다.

상기 시스템은,

- (1) 위협 이벤트 계층(Threat Event Layer) 과
 - (2) 분석 및 평가 계층(Vulnerability & Risk Analysis Layer)
- 의 두 계층으로 구성된다.

(1) 위협 이벤트 계층 (Threat Event Layer)

상기 위협 이벤트 계층은 다음 구성요소들을 포함한다.

- Threat Modeling as Code(TMnC)를 참조하여 동작하는 Policy Gateway
- 상기 Policy Gateway 의 내부 또는 인접 계층에 배치된 Threat Signal Engine
- Threat Evaluation Store

상기 위협 이벤트 계층은, 개별 요청, 응답 및 테스트 이벤트 단위로 AI Boundary 기반 Threat 에 대한 위협 시그널(score)을 수집하고, 이를 구조화된 형태로 저장하는 계층이다.

(2) 분석 및 평가 계층 (Vulnerability & Risk Analysis Layer)

상기 분석 및 평가 계층은 다음 구성요소를 포함한다.

- Boundary Vulnerability / Risk Calculator

상기 분석 및 평가 계층은, 위협 이벤트 계층으로부터 저장된 Threat 평가 정보를 기반으로, AI Boundary 단위의 취약성 수준 및 Risk 를 분석·산출하기 위한 계층이다.

3.2.1 기존 구조 및 동작 방법

기존 AI 추론 시스템은 일반적으로, 클라이언트(모바일, 웹 또는 디바이스)에서 입력을 수신하여 백엔드 서비스를 거쳐 AI 추론 엔진 또는 LLM Provider API 를 호출하는 구조를 갖는다.

또는, 일부 시스템은 온디바이스(on-device) AI 추론 프레임워크를 사용하며, RAG 인덱스, 외부 도구 또는 플러그인, 로깅 및 모니터링 시스템을 포함할 수 있다.

기존 보안 대책은 주로 다음과 같은 방식으로 적용된다.

- 입력 필터링(키워드, 정규식 기반)
- 정적 프롬프트 가이드 적용
- AI 제공자 측 safety 옵션 활용

- 로그 기반 사후 분석 및 수동 E2E 테스트

그러나 이러한 방식은,

- AI Boundary 단위의 Threat(T-01~T-xx)를 체계적으로 관리하기 어렵고,
- Threat Modeling 문서와 실제 정책, 탐지 및 테스트 간의 계층적 일관성 및 동기화가 보장되지 않으며,
- Risk 기반의 보안 통제 우선순위 조정이나 재학습·테스트 강화가 자동화되기 어렵다는 한계를 갖는다.

3.2.2 제안 시스템 구조

본 발명에 따른 시스템은,

Threat Modeling as Code(TMaC)를 중심으로 구성되며,

AI Boundary 단위에서의 위협 탐지, 정책 적용, 테스트 및 위험 평가를 일관되게 수행하도록 상호 연계된 여러 구성 요소들로 이루어진다.

시스템은 다음과 같은 구성 요소들로 이루어진다.

- Threat Modeling as Code (TMaC) 스키마 및 AI Boundary Threat Taxonomy
- Policy Gateway (Boundary Gateway)
- Threat Signal Engine
- Threat Evaluation Store
- Boundary Vulnerability / Risk Calculator
- E2E Boundary Test Pack

각 구성 요소의 역할은 다음과 같다.

(1) Threat Modeling as Code (TMaC) 스키마 및 AI Boundary Threat Taxonomy

TMaC 스키마는 YAML 등 기계 가독 포맷으로 작성되며,

다음과 같은 정보를 포함할 수 있다.

- Boundaries:
 - Boundary 의 이름(name)
 - Boundary 에서 처리되는 데이터 종류(data_kinds)
 - Boundary 에서 적용 가능한 제어 항목(control_kinds)
- AI Boundary Threats:
 - Threat 식별자(ID, T-01~T-xx), 코드 및 명칭
 - Threat 가 적용되는 Boundary 목록(boundaries)

- 기본 위험 요소(impact, likelihood, base_risk)
 - Threat 의 영향을 받는 데이터 및 제어 항목
(affected_data_kinds, affected_control_kinds)
- Policy:
 - Threat-Boundary 조합별 정책(action)
 - 정책 적용 임계값(threshold)
- Test:
 - Threat 시나리오 ID
 - 적용 Boundary
 - 입력 데이터 및 기대 결과를 포함하는 E2E 테스트 케이스 정의

TMaC 스키마 전체 구조 예시 (일 실시예)

※ 이하 스키마는 설명을 위한 예시이며, 본 발명의 범위를 한정하지 않는다.

```

boundaries:
- name: prompt
  data_kinds:
    - content.system_prompt
    - content.user_text
  control_kinds:
    - env.safety_mode
    - policy.decision
ai_boundary_threats:
- id: T-01
  code: T_PROMPT_INJECTION
  name: "Direct Prompt Injection"
  boundaries: ["prompt", "input"]
  impact: high
  likelihood: high
  base_risk: high
  affected_data_kinds:
    - content.system_prompt
    - content.user_text
  affected_control_kinds:
    - policy.decision
    - env.safety_mode
  
```

TMaC 스키마의 활용

상기 TMaC 스키마는 다음과 같은 용도로 활용된다.

- Policy Gateway 설정의 자동 생성
- Threat Signal Engine 에서 산출된 위협 시그널(score)을 특정 AI Boundary Threat ID 에 매핑하기 위한 기준 제공
- Boundary Test Pack 의 E2E 테스트 케이스 생성
- Boundary Vulnerability 및 Risk 계산 시 Threat-Boundary 매핑 기준 제공

AI Boundary Threat Taxonomy 는 AI Boundary 단위에서 발생 가능한 위협 유형을 Threat ID, 명칭 및 적용 Boundary 기준으로 정리한 것이다.

예를 들어, 다음과 같은 AI Boundary Threat 들을 포함할 수 있으며, 이에 한정되지 않는다.

Threat ID	Threat Name	적용 Boundary
T-01	Direct Prompt Injection	Input, Prompt
T-02	Indirect Prompt Injection (RAG)	Retrieval, Prompt
T-03	Data Re-Exposure	Output
T-04	Tool Privilege Misuse	Tool
T-05	Resource Abuse / Surge	Input, Provider
T-06	Compliance Violation	Output, Policy
T-07	Malicious Output / Link	Output
T-08	Provider Failure / Safety Control Desynchronization	Provider

(2) Policy Gateway (Boundary Gateway)

Policy Gateway 는 각 AI Boundary 상에 위치하여,
TMaC 스키마에 정의된 정책에 따라
AI 요청 또는 응답에 대한 보안 통제를 실시간으로 수행하는 구성 요소이다.

Policy Gateway 는
Threat Signal Engine 이 산출한 위협 시그널(score)을 입력으로 받아,
allow, block, sanitize, ask_human, log_only, rate_limit 등의
정책 결정을 수행하며, 그 결과를 Threat Evaluation Store 에 기록한다.

(3) Threat Signal Engine (위협 시그널 엔진)

Threat Signal Engine 은 특정 AI Boundary 에서 발생한 이벤트
(입력 텍스트, 출력 텍스트, 검색 결과, 도구 실행 결과, 메타데이터 등)를 입력으로 받아,
하나 이상의 AI Boundary Threat 에 대한
위협 시그널(score)을 산출하는 구성 요소이다.

상기 Threat Signal Engine 은
위협의 최종 판정을 수행하지 않으며,

TMaC 에 정의된 Threat 에 대한
유사도 또는 발생 가능성을 수치화한 시그널만을 제공한다.

(4) Threat Evaluation Store (위협 이벤트 저장소)

Threat Evaluation Store 는
Policy Gateway 및 Threat Signal Engine 에 의해 생성된
위협 평가 이벤트를 시간 축으로 수집·저장하는 데이터 저장소이다.

상기 위협 평가 이벤트는
Threat score, 적용된 정책(action), 테스트 결과 및 관련 메타데이터를 포함하며,
이후 AI Boundary Vulnerability 및 AI Boundary Risk 를
산출·갱신하기 위한 분석 입력 데이터로 활용된다.

(5) Boundary Vulnerability / Risk Calculator (분석/평가 계층)

Boundary Vulnerability / Risk Calculator 는
Threat Evaluation Store 에 저장된 위협 이벤트들과,
TMaC 스키마에 정의된 Threat–Boundary–Control 매핑 및
정책 적용 범위를 입력으로 받아,

각 AI Boundary–AI Boundary Threat 조합에 대한
AI Boundary Vulnerability 및 AI Boundary Risk 를
정량적으로 산출·갱신하는 분석 또는 평가 계층이다.

(6) E2E Boundary Test Pack

E2E Boundary Test Pack 은
TMaC 스키마에 정의된 AI Boundary Threat 및 시나리오에 대응하여,
각 AI Boundary 를 대상으로 수행되는
자동화된 공격 또는 검증 테스트 집합이다.

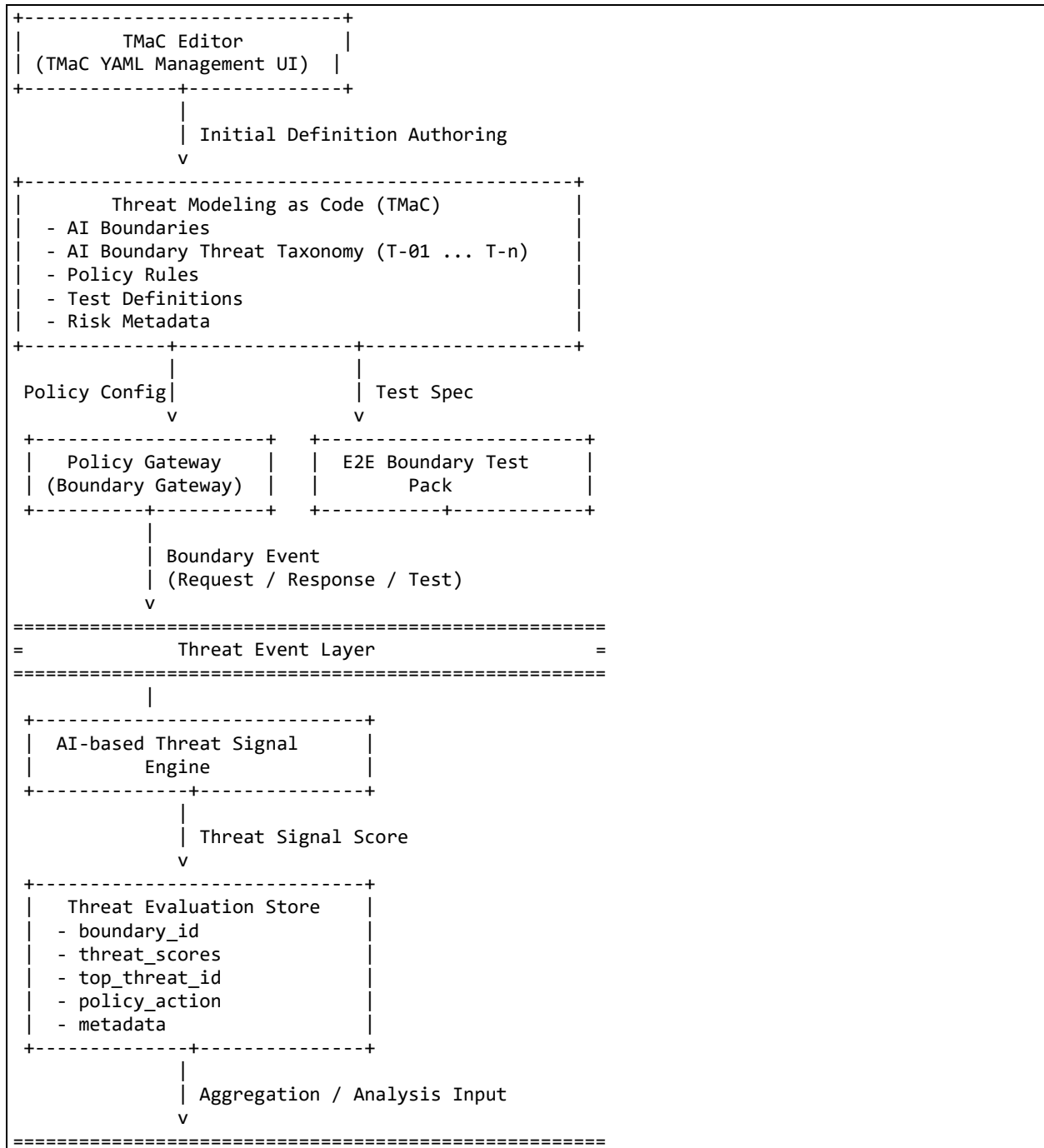
상기 테스트 결과는
Threat Evaluation Store 에 저장되어,
AI Boundary Risk 계산 및 정책 조정에 활용된다.

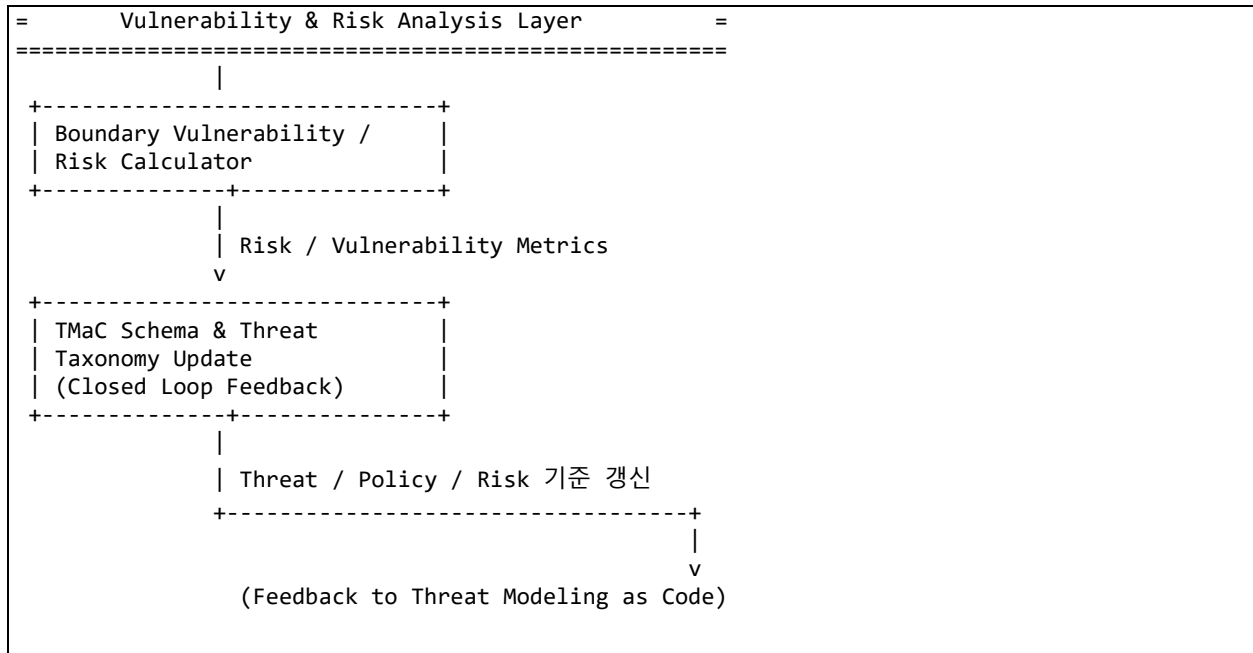
3.2.3 Closed Loop 기반 AI Boundary 처리 워크플로우

(1) 전체 동작

본 발명에 따른 Boundary-Centric Threat Modeling as Code(TMaC) 기반 시스템의 전체 동작은, AI Boundary 단위에서 발생하는 Threat 이벤트를 수집·평가하는 **Threat Event Layer** 와, 상기 Threat 이벤트를 분석하여 Boundary 단위 취약성 및 Risk 를 산출하고 그 결과를 다시 기준 정의에 반영하는 **Vulnerability & Risk Analysis Layer** 를 포함하는 **Closed Loop 구조**를 기반으로 수행된다. 상기 전체 동작은 *Boundary-Centric Threat Modeling as Code(TMaC) 기반 전체 시스템 구조*에 도시된 바와 같은 구성 요소들의 상호작용에 의해 구현된다.

그림) Boundary-Centric Threat Modeling as Code (TMaC) 기반 전체 시스템 구조





[메모] Q3. 사용자 피드백 UI (block / sanitize) - 위치 관계

[Threat Signal Engine]

```

|
v
[Policy Gateway]
- policy_action:
  . allow
  . sanitize
  . block
  |
  v

```

```

=====
| Application / UI Layer |
|-----|
| - 정책 결과 표시      |
|   . "요청이 차단됨"   |
|   . "민감 정보가 마스킹됨" |
| - 재입력 / 재시도 안내 |
|-----|
=====

```

※ UI 는 Threat 판단 주체 아님

※ Risk 계산 및 기준 갱신 관여 하지 않음

※ Policy Gateway 의 결정 결과를 표현만 수행

[메모] Q4. 온디바이스 / 클라우드 LLM 환경에서의 구성요소 위치

(A) 온디바이스 LLM 환경

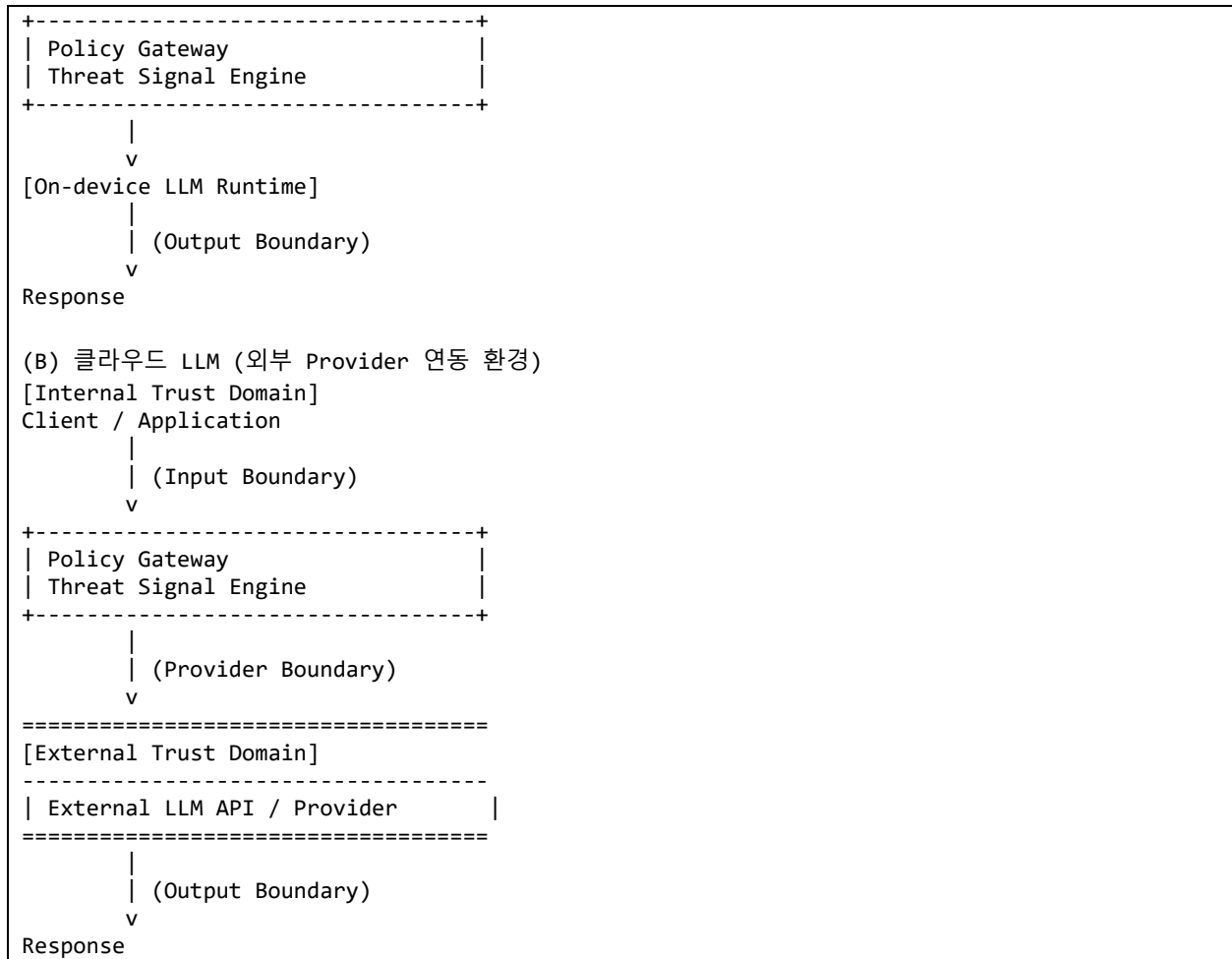
[Internal Trust Domain]

Client / Application

```

|
| (Input Boundary)
v

```



(A) Threat Event Layer 워크플로우

Threat Event Layer 는 AI 추론 시스템의 실제 동작 과정에서 발생하는 **요청, 응답 및 테스트 이벤트**를 AI Boundary 단위로 처리하고, 이를 **Threat 수준의 이벤트로 변환·기록**하는 계층이다.

구체적으로, 클라이언트 또는 애플리케이션으로부터 입력된 요청은 **Policy Gateway** 를 통해 하나 이상의 AI Boundary 로 매핑된다.

Policy Gateway 는 TMaC 에 정의된 Policy 및 Threat 정보를 참조하여, 요청 처리 과정에서 발생하는 **Boundary 이벤트**를 생성한다.

상기 Boundary 이벤트는 **AI 기반 Threat Signal Engine** 으로 전달되며, Threat Signal Engine 은 요청 내용, 응답 내용 또는 실행 컨텍스트를 분석하여 **Threat ID 단위의 시그널 점수 또는 판단 결과**를 산출한다.

산출된 Threat 시그널 평가 결과는 **Threat Evaluation Store** 에 저장된다.

Threat Evaluation Store 에는 Boundary 식별자, Threat 시그널 점수, 최상위 Threat ID, 적용된 Policy 동작 결과 및 관련 메타데이터가 구조화된 형태로 누적 저장되며, 이를 통해 Threat 이벤트는 **일회성 로그가 아닌 분석 가능한 상태 정보**로 관리된다.

(B) Vulnerability & Risk Analysis Layer 워크로우

Vulnerability & Risk Analysis Layer 는 Threat Event Layer 에서 축적된 Threat 이벤트를 기반으로, **AI Boundary** 단위의 취약성 및 Risk 를 분석·산출하는 계층이다.

Boundary Vulnerability / Risk Calculator 는 Threat Evaluation Store 에 저장된 Threat 이벤트를 집계·분석하여,

특정 AI Boundary 와 AI Boundary Threat 의 조합에 대한 **취약성 수준 및 Risk 값**을 산출한다.

이때 Risk 는 Threat 발생 가능성과 발생 시 영향을 결합하여 평가되며,

Threat 이벤트의 실제 발생 양상과 Policy 적용 결과를 반영하여 **동적으로 계산**된다.

상기 분석 결과는 **TMaC Schema 및 AI Boundary Threat Taxonomy 의 갱신(Update)**에 활용되며, Threat 정의, Policy 조건 및 Risk 메타데이터 등이 조정될 수 있다.

이와 같은 기준 갱신은 TMaC 에 반영되어 이후의 Threat 평가 및 정책 적용에 재사용됨으로써,

시스템은 동일한 Threat 유형에 대해 **점진적으로 강화된 대응 기준**을 유지한다.

(C) Closed Loop 워크로우

이와 같이, 본 발명의 전체 동작은

TMaC 에 정의된 기준에 따라 Threat 이벤트를 처리하고,

처리 결과를 분석하여 Risk 를 산출한 후,

상기 분석 결과를 다시 **TMaC 정의의 갱신(Update)**에 반영하는 **Closed Loop** 구조를 형성한다.

상기 Closed Loop 구조에서,

TMaC 정의의 **초기 생성**은 설계 단계에서 수행되며,

Threat 이벤트 처리 결과에 따른 **TMaC 정의의 갱신(Update)**은 분석·평가 결과에 의해 수행된다.

이에 따라, 본 발명의 시스템은 AI Boundary 단위 Threat 처리 기준을 정적으로 고정하지 않고,

실제 운영 환경에서 발생하는 Threat 이벤트를 반영하여 **지속적으로 보정·강화되는 보안 처리 구조**를 제공한다.

[실시예] AI Boundary 기반 Threat 처리 예

본 발명의 Boundary-Centric Threat Modeling as Code(TMaC) 기반 시스템은, AI Boundary 를 횡단하는 요청에 대해 Threat 이벤트를 식별하고, 사전에 정의된 Policy 에 따라 적절한 제어를 수행하며, 그 처리 결과를 기반으로 기준을 갱신하는 Closed Loop 구조를 통해 동작한다. 이하에서는 대표적인 실시예를 통해 이를 설명한다.

(실시예 1) 민감 정보가 포함된 요청 처리

사용자 요청에 개인정보 또는 민감 정보가 포함된 경우,

해당 요청은 AI Boundary 단위의 Threat 이벤트로 식별된다.

예를 들어, 사용자 입력에 전화번호, 계좌번호 또는 식별 가능한 개인정보가 포함된 경우,

상기 요청은 Policy Gateway 를 통해 해당 AI Boundary 로 매핑되고,

AI 기반 Threat Signal Engine 에 의해 **민감 정보 노출 Threat**에 대한 시그널이 평가된다.

Threat 시그널이 사전에 정의된 임계값 이상으로 평가된 경우,
상기 Policy 는 요청을 전면 차단하지 않고,
해당 민감 정보를 마스킹, 일반화 또는 치환하는 **콘텐츠 변형 제어(Content Transformation Control)**
를 수행한다.
변형된 요청은 이후의 AI 추론 과정에 전달되며,
상기 Threat 평가 결과 및 Policy 적용 결과는 Threat Evaluation Store 에 기록된다.

(실시예 2) 외부 Web Search 또는 도구 호출 요청 처리

AI 추론 과정에서 외부 Web Search 또는 외부 도구 호출이 발생하는 경우,
해당 호출은 **외부 신뢰 경계를 횡단하는 AI Boundary 이벤트**로 처리된다.
이 경우, Policy Gateway 는 외부 도구 호출 요청을 별도의 Boundary 이벤트로 식별하고,
AI 기반 Threat Signal Engine 을 통해 외부 자원 호출에 따른 Threat 시그널을 평가한다.
Threat 평가 결과에 따라, 상기 Policy 는

- 외부 도구 호출을 제한하거나,
- 허용된 도메인 또는 기능으로 호출 범위를 축소하거나,
- 특정 조건에서 호출을 차단하는 **호출 제어(Invocation Control)** 를 수행할 수 있다.

상기 외부 도구 호출 이벤트 및 Policy 적용 결과는 Threat Evaluation Store 에 기록되며,
외부 의존성에 따른 Risk 분석에 활용된다.

(기준 갱신 및 Closed Loop 동작)

상기 실시예들에서 생성된 Threat 이벤트 및 Policy 적용 결과는
Vulnerability 및 Risk 분석 단계에서 집계·분석되며,
그 결과에 따라 Threat 정의, Policy 임계값 또는 제어 방식이 **TMaC 정의에 갱신(Update)** 될 수 있다.
갱신된 TMaC 정의는 이후 발생하는 동일 유형의 요청에 적용됨으로써,
시스템은 운영 환경에서 관측된 Threat 특성을 반영하여
AI Boundary 단위 Threat 처리 기준을 지속적으로 보정·강화한다.

4. Claims of the Invention (청구범위)

[Claim 1] – 메인 독립항 (System Claim)

“이 발명의 본체”

전체 구조(모듈 구성)를 한 번에 잡는 최상위 시스템 청구항.

포함 내용:

- TMaC 모듈

- Policy Gateway
- Threat Signal Engine
- Threat Evaluation Store
- Boundary Vulnerability / Risk Calculator

"Boundary-Centric TMaC + Gateway + Signal + Store + Risk 분석 레이어를

"AI/LLM 보안을 위한 Boundary-Centric Risk-Driven 시스템"을 구조·역할·데이터 흐름의 관점에서 보호한다

- AI Boundary 및 AI Boundary Threat, 정책, 테스트를 기계 가독 스키마로 정의하는 Threat Modeling as Code(TMaC) 모듈;
- 상기 TMaC 모듈을 기반으로, 상기 AI Boundary 를 통과하는 요청 또는 응답에 대하여 정책을 적용하는 Policy Gateway;
- 상기 Policy Gateway 와 연동되어, 상기 AI Boundary 에서 발생하는 이벤트(입력/출력 텍스트, 검색 결과, 도구 결과, 메타데이터 등)를 입력으로 받아, 하나 이상의 AI Boundary Threat 에 대한 score 또는 시그널 값을 산출하는 Threat Signal Engine;
- 상기 Threat Signal Engine 이 산출한 score 및 상기 Policy Gateway 가 적용한 정책(action), 테스트 결과(PASS/FAIL), 관련 메타데이터를 위협 평가 이벤트 단위로 저장하는 Threat Evaluation Store;
- 상기 Threat Evaluation Store 에 저장된 위협 평가 이벤트들과, 상기 TMaC 모듈에 정의된 Threat-Boundary-Control 매핑 및 정책 적용 범위를 입력으로 받아, AI Boundary Threat-Boundary 조합별 AI Boundary Vulnerability 및 AI Boundary Risk 를 산출하는 Boundary Vulnerability / Risk Calculator;

를 포함하는 것을 특징으로 하는 시스템.

[Claim 2] – Risk 계산 로직을 포함하는 시스템

청구항 1 에 있어서,

상기 Boundary Vulnerability / Risk Calculator 는, 특정 AI Boundary Threat-AI Boundary 조합에 대하여, 위협 시그널 점수가 소정 임계값을 초과하는 빈도,

상기 Policy Gateway 에 의해 수행된 **정책 제어 동작(action)의 비율(allow, sanitize, block 등)**, 및 테스트 결과의 성공 또는 실패 비율

중 적어도 둘 이상을 결합하여, 상기 AI Boundary Vulnerability 및 AI Boundary Risk 를 계산하는 것을 특징으로 하는 시스템.

[Claim 3] – Risk 기반 기준 갱신을 포함하는 Closed Loop 시스템

청구항 1 또는 청구항 2에 있어서,
상기 Boundary Vulnerability / Risk Calculator가 산출한 **AI Boundary Risk**를 입력으로 받아,
상기 AI Boundary Risk가 소정 임계값을 초과하는 경우,
Threat Modeling as Code(TMaC)에 정의된 Threat 정의 또는 정책을 갱신하거나,
Policy Gateway의 정책 제어 기준을 조정하거나,
Threat Signal Engine의 탐지 기준 또는 모델 파라미터를 재조정하거나,
테스트 수행의 우선순위를 변경하는 것
중 적어도 하나 이상을 시스템 내부 구성요소의 기준으로 갱신, 조정 또는 변경하도록 기준으로 갱신, 조정 또는 변경 되도록 하는 것을 특징으로 하는 시스템.

[메모]

Risk Calculator → AI Boundary Risk → 시스템 내부 구성요소 기준 → 다음 동작 / 요청에 반영
(산출) (입력으로 사용) (갱신/조정/변경)

[Claim 4] – Threat Signal Engine의 구현 구성을 포함하는 시스템

청구항 1에 있어서, 상기 Threat Signal Engine은,
사전 학습된 언어 모델 기반의 위협 분류기,
규칙 기반의 위협 탐지기,
또는 이들의 조합을 포함하여 구현되는 것을 특징으로 하는 시스템.

[메모]

Claim 4는 Threat Signal Engine의 구현 구성을 모델 기반, 규칙 기반 또는 그 조합으로 한정함으로써, 특정 구현 방식에 의존하지 않도록 하고 회피 설계를 방지하기 위한 종속항임.

[Claim 5] – AI Boundary 기반 Risk-Driven 보안 처리 방법 (방법 청구항)

상기
TMaC를 기반으로 Policy Gateway 및 Threat Signal Engine을 구성하는 단계;
AI Boundary를 통과하는 요청, 응답 또는 테스트 이벤트로부터 Threat 신호를 산출하고
정책을 적용하며 그 결과를 Threat Evaluation Store에 기록하는 단계;
상기 Threat Evaluation Store의 정보를 이용하여
상기 AI Boundary Threat-Boundary 조합별 Vulnerability 및 Risk를 계산하는 단계;

상기 계산된 AI Boundary Risk 를 입력으로 하여
TMaC, 정책 기준, 탐지 기준 또는 테스트 수행 기준 중
적어도 하나를 갱신, 조정 또는 변경하는 단계를 포함하는 것을 특징으로 하는 방법

[메모]

Claim 1 – 시스템 전체 아키텍처를 잡는 독립항

Claim 2 – Risk 계산 로직(Threat Event + Policy + Test) 디테일

Claim 3 – Risk 기반 피드백/자동화 액션 (Closed Loop)

Claim 4 – Threat Signal Engine 구현 형태 (LLM 기반 + 룰 기반 등)

Claim 5 – 동일 개념을 “방법(Method)” 측면에서 다시 보호

- “무엇으로 구성된 시스템인지” (구조)
- “그 시스템이 뭘 계산하는지” (Risk)
- “그걸 보고 어떻게 자동으로 대응하는지” (피드백)
- “탐지 엔진은 어떤 식으로 구현 가능한지” (실시예)
- “이 모든 걸 단계적으로 수행하는 방법” (방법청구)

5. Effects of the Invention (발명의 효과)

본 발명에 따르면, 다음과 같은 효과를 얻을 수 있다.

1. AI Boundary 단위 Threat-Vulnerability-Risk 구조화

Threat Signal Engine 및 Threat Evaluation Store 는 요청 또는 이벤트 단위의 위협 시그널을 수집하고,
Boundary Vulnerability / Risk Calculator 는 TMaC 설계 정보 및 정책·테스트 적용 현황과 결합하여
Boundary-Threat 단위의 취약성 및 Risk 를 정량화함으로써,
Threat-Vulnerability-Risk 관계를 AI Boundary 수준에서 명확하게 구조화할 수 있다.

2. 설계-정책-위협 시그널-테스트-위험 평가의 Closed Loop 구현

TMaC 를 중심으로 Policy Gateway, Threat Signal Engine, E2E Test, Threat Evaluation Store 및
Boundary Vulnerability / Risk Calculator 가 연계됨으로써,
설계 단계에서 정의된 Threat 모델과 운영 중 적용되는 정책·탐지·테스트 간의 불일치를 줄이고,
Risk 기반으로 보안 통제 및 자원(탐지·테스트·튜닝)의 우선순위를 조정할 수 있다.

3. LLM 기반 서비스 및 기타 AI 추론 시스템에 특화된 Boundary-Centric 보안 프레임워크 제공

OWASP Top 10 for LLM vulnerabilities 등 LLM 특화 취약점을
AI Boundary Threat Taxonomy 로 재구성하고,
이를 TMaC 스키마, Policy Gateway, Threat Signal Engine 및
Boundary Vulnerability / Risk Calculator 와 연계함으로써,

LLM 기반 서비스 및 유사한 AI 추론 시스템의 보안을 설계-구현-테스트-운영 관점에서 일관되게 관리할 수 있다.

[메모]

[Claim 1] Boundary-Centric 구성 + TMaC + Gateway + Signal + Store + Risk Calculator

↓

[Claim 2] Risk = score + policy action + test 결과의 결합값

↓

[Claim 3] Risk 를 입력으로 사용하여 시스템 내부 기준을 갱신

↓

[Claim 5] 이 구조를 실제 운용 절차(method)로 수행

↓

[Effects]

- Risk 를 정량화할 수 있다
- Risk 기반으로 기준을 바꿀 수 있다
- 운영 중에도 보안이 유지된다

[구현 범위 보강 – Claim 4]

- Threat Signal Engine 은
 - 모델 기반
 - 규칙 기반
 - 또는 이들의 조합으로 구현 가능